Office of Information Technology Services

State Capitol P.O. Box 2062
Albany, NY 12220-0062
www.its.ny.gov

New York State Information Technology Standard	**No:** NYS-S17-003
IT Standard: **Notification Standard for Certain Types of Regulated Data**	**Updated:** 1/12/2026
	Issued By: NYS Office of Information Technology Services **Owner:** Division of Legal Affairs

1.0 Purpose and Benefits

The purpose of this standard is to provide State Entities (SE) with information on breach notification and reporting requirements for some specific types of data subject to various legal and regulatory requirements. Please note that this standard does not address *all* regulated data types, so each SE must consult with its legal counsel to determine applicable requirements.

2.0 Authority

Section 103(10) of the State Technology Law provides the Office of Information Technology Services (ITS) with the authority to establish statewide technology policies, including technology and security standards. *Section 2 of Executive Order No. 117*[1] provides the State Chief Information Officer with the authority to oversee, direct and coordinate the establishment of information technology policies, protocols and standards for State government, including hardware, software, security and business re-engineering. Details regarding this authority can be found in NYS ITS Policy, *NYS-P08-002 Authority to Establish State Enterprise Information Technology (IT) Policy, Standards and Guidelines*.

[1] All references to Executive Order 117 refer to that which was originally issued by Governor George E. Pataki on January 28, 2002 and continued by Executive Order 5 issued by Governor Eliot Spitzer on January 1, 2007, Executive Order 9 issued by Governor David A. Patterson on June 18, 2008, and Executive Order 2 issued by Governor Andrew M. Cuomo on January 1, 2011, and Executive Order 6 issued by Governor Kathy Hochul on October 8, 2021.

3.0 Scope

This standard applies to all "State Entities" ("SE") defined as "State Government" in Executive Order 117 or "State Agencies" as defined in Section 101 of the State Technology Law. This includes employees and all third parties (such as local governments, consultants, vendors, and contractors) that use or access any Information Technology (IT) Resource for which the SE or ITS has administrative responsibility, including systems managed or hosted by third parties on behalf of the SE or ITS. While an SE may adopt a different standard, it must include the requirements set forth in this one. Where a conflict exists between this standard and an SE's standard, the more restrictive standard will take precedence.

This standard does not apply to individual members of the State workforce who, pursuant to NYS-P14-001 Acceptable Use of Information Technology Resources Policy, must immediately report suspected computer security incidents to the appropriate manager and the Information Security Officer (ISO)/designated security representative.

4.0 Information Statement

NYS-S13-005 Cyber Incident Response Standard identifies Incident Response Stakeholder Roles and Responsibilities and the Incident Response Process Flow. Each SE must assign responsibility for a central point of contact to coordinate identification of an incident and reporting an incident to the ITS Chief Information Security Office.

In addition, NYS-P03-002 Information Security Policy details that SE executive management is responsible for: complying with notification requirements in the event of a breach of private information; adhering to specific legal and regulatory requirements related to information security; and communicating legal and regulatory requirements to the ISO/designated security representative.

The standards below set forth external notification and reporting requirements for some data types as required by the specific entities referenced herein and are intended to assist SE executive management in meeting their responsibilities. Each SE should have documented procedures that reflect their compliance with applicable notification requirements, and should include specific names, titles, or functions of the individuals responsible for each stage of the notification process. The document should include detailed instructions for how, and to whom each employee, contractor, agent, or other third-party should report the incident. Any external notification and reporting from an SE to an external entity should only occur pursuant to their SE incident response protocol and after proper coordination with SE executive management, legal counsel, Information Security Officer (ISO)/designated security representative, and other stakeholders as appropriate.

Notification and Reporting Requirements for Specific Data Types

Social Security Administration (Personally Identifiable Information)

The SE will comply with limitations on use, treatment, and safeguarding of data under the Privacy Act of 1974 (5 U.S.C. 552a), related Office of Management and Budget guidelines, the Federal Information Security Management Act of 2002 (44 U.S.C. § 3541, et seq.), and related National Institute of Standards and Technology guidelines. In addition, the SE will comply with the Social Security Administration's ("SSA") "Electronic Information Exchange Security Requirements and Procedures for State and Local Agencies Exchanging Electronic Information with the Social Security Administration" included as part of its Information Exchange Agreement or State Transmission/Transfer Component Agreement, as applicable, with the SSA.

If the SE experiences or suspects a breach or loss of PII or a security incident, which includes SSA-provided information, they must notify the State official responsible for Systems Security designated in the agreement. That State official or delegate must then notify the SSA Regional Office Contact or the SSA Systems Security Contact identified in the agreement. If, for any reason, the responsible State official or delegate is unable to notify the SSA Regional Office or the SSA Systems Security Contact **within one hour**, the responsible State Agency official or delegate must report the incident by contacting **SSA's National Network Service Center (NNSC) toll free at 1-877-697-4889** (select "Security and PII Reporting" from the options list). The EIEP will provide updates as they become available to SSA contact, as appropriate. Refer to the worksheet provided in the agreement to facilitate gathering and organizing information about an incident.

Internal Revenue Service (Federal Tax Information)

Pursuant to Section 1.8.2 of IRS Publication 1075, upon discovering a possible improper inspection or disclosure of FTI, including breaches and incidents (as defined by IRS Publication 1075), by a state employee or any other person, the individual making the observation or receiving information must contact the Treasury Inspector General for Tax Administration (TIGTA) Field Division office, to the Special Agent-in-Charge, immediately, but no later than 24 hours after identification of a possible issue involving FTI. If unable to contact the local TIGTA Field Division Office, contact the Hotline Number: 800-366-4484.

- Concurrent to notifying TIGTA, the SE must notify the Office of Safeguards by email to Safeguards mailbox, safeguardreports@irs.gov. To notify the Office of Safeguards, the SE must document the specifics of the incident known at that time into a data incident report, including but not limited to:

- Name of agency and agency Point of Contact for resolving data incident with contact information

- Date and time the incident/breach occurred

- Date and time the incident/breach was discovered

- How the incident/breach was discovered
- Description of the incident/breach and the data involved, including specific data elements, if known
- Potential number of FTI records involved; if unknown, provide a range if possible
- Address where the incident/breach occurred
- IT involved (e.g., laptop, server, mainframe)
- Does the incident involve an unauthorized access or disclosure by an agency employee? (Y/N)

If a criminal indictment is not pursued, will a disciplinary or adverse action be proposed against the agency employee involved in this unauthorized access or disclosure? (Y/N)

Reports must be sent electronically and encrypted via IRS-approved encryption techniques. Use the term "data incident report" in the subject line of the email. Do not include any FTI in the data Incident report. Even if all information is not available, immediate notification is the most important factor, not the completeness of the report. Additional information must be provided to the Office of Safeguards as soon as possible.

SEs are not to wait until after their own internal investigation has been conducted. The IRS Office of Safeguards investigation focuses on identifying processes, procedures or systems within the agency with inadequate security controls which led to the incident.

SEs must provide written notification to a taxpayer whose FTI was subject to unauthorized access or disclosure when a disciplinary or adverse action is proposed against the SE employee responsible. The required written notification to the taxpayer must include the date of the unauthorized inspection or disclosure and the rights of the taxpayer under IRC § 7431.

Federal Bureau of Investigation (Criminal Justice Information Services (CJIS))

The SE shall promptly report incident information to the SE ISO/designated security representative and the CJIS System Agency Information Security Officer for New York State. Information security events and weaknesses associated with information systems shall be communicated in a manner allowing timely corrective action to be taken. Formal event reporting and escalation procedures shall be in place. Wherever feasible, the SE shall employ automated mechanisms to assist in the reporting of security incidents. All employees, contractors and third-party users shall be made aware of the procedures for reporting the different types of event and weakness that might have an impact on the security of agency assets and are required to report any information security events and weaknesses as quickly as possible to the designated point of contact: the SE ISO/designated security representative and the CJIS System Agency (CSA) Information Security Officer for New York State.

Department of Health & Human Services (HIPAA/HITECH)

In addition to notifying affected individuals and the media (where appropriate), covered entities must notify the Secretary of Health and Human Services of breaches of unsecured protected health information. Covered entities notify the Secretary by visiting the HHS web site at: and filling out and electronically submitting a breach report form through the HHS web portal. If a breach affects 500 or more individuals, covered entities must notify the Secretary without unreasonable delay and in no case later than 60 days from the discovery of the breach. If, however, a breach affects fewer than 500 individuals, the covered entity must notify the Secretary of the breach within 60 days of the end of the calendar year in which the breach was discovered. The covered entity may report all of its breaches affecting fewer than 500 individuals on one date, but the covered entity must complete a separate notice for each breach incident.

Center for Medicaid Services

Known or suspected security incidents involving CMS data must be reported immediately to the CMS IT Service Desk by calling 410-786-2580 or 1-800-562-1963 or via e-mail to CMS_IT_Service_Desk@cms.hhs.gov. Even if you are not positive, but only suspect that it might be a security incident, you must still submit a report and allow the experts to determine whether or not it is a security incident. Any suspected loss or unauthorized disclosure of CMS data must be reported within one hour of discovery.

After notifying the CMS IT Service Desk, collect as much supporting information as possible on the suspected security and privacy incident using the Incident Response Reporting Template. Provide the information contained on the completed incident reporting form to the CMS IT Service Desk.

Payment Card Industry Data Security Standards

The PCI DSS requirements are developed and maintained by an industry standards body called the PCI Security Standards Council (SSC). The standards are enforced by the five payment card brands: Visa, MasterCard, American Express, JCB International and Discover. Each brand provides *its own* compliance guidelines, reporting and validation requirements, deadlines, brand-specific definitions and penalties for noncompliance. Service providers should therefore obtain notice and reporting requirements directly from the individual card brands.

Family Educational Rights and Privacy Act (FERPA; PII in Educational Record Keeping)

There is not a notification or disclosure requirement under FERPA, however, there is a requirement to record access and disclosures (34 CFR § 99.32). In addition, the U.S. Department of Education considers notification a best practice. Furthermore, New York State Education Law Section 2-d includes notification requirements in the event of an unauthorized release of student data.

5.0 Compliance

This standard shall take effect upon publication. Compliance is required with all enterprise policies and standards. ITS may amend its policies and standards at any time; compliance with amended policies and standards is required.

6.0 Definitions of Key Terms

Except for terms defined in this policy, all terms shall have the meanings found in http://www.its.ny.gov/glossary.

7.0 Contact Information

Submit all inquiries and requests for future enhancements to the policy owner at:

Division of Legal Affairs
Reference: NYS-S17-003
NYS Office of Information Technology Services
State Capitol, PO Box 2062
Albany, NY 12220-0062
Telephone: (518) 473-5115
Email: its.sm.dla@its.ny.gov

Statewide technology policies, standards, and guidelines may be found at the following website: https://its.ny.gov/policies

8.0 Revision History

This standard should be reviewed consistent with the requirements set forth in ITS-P24-003 Process for Establishing Information Technology Polices, Standards and Guidelines.

Date	Description of Change	Reviewer
01/30/2018	Original Standard Released	Division of Legal Affairs
12/04/2020	Updated Standard	Division of Legal Affairs
01/12/2026	Updated IRS section	Division of Legal Affairs

9.0 Related Documents

NYS Information Security Policy

NYS Cyber Incident Response Standard

NYS Cyber Incident Response Procedures